MF0488_3 –GESTIÓN DE INCIDENTES DE SEGURIDAD INFORMÁTICA

1. Sistemas de Detección y Prevención de Intrusiones (IDS/IPS)
2. Implantación y Puesta en Producción de Sistemas IDS/IPS
3. Control de Código Malicioso
4. Respuesta ante Incidentes de Seguridad
5. Proceso de Notificación y Gestión de Intentos de Intrusión
6. Análisis Forense Informático

Módulo 3 Control de Código malicioso

Objetivos:

Analizar los Sistemas, técnicas y herramientas implicados en la detección, contención, análisis y neutralización del código malicioso, estableciendo criterios técnicos para su configuración, actualización, supervisión y validación en entornos profesionales, conforme a normativas de ciberseguridad.

Contenido:

1. Sistemas de detección y contención del código malicioso
2. Relación de los distintos tipos de herramientas de control de código malicioso en función de la topología de la instalación y las vías de infección a controlar
3. Criterios de seguridad para la configuración de las herramientas de protección frente a código malicioso
4. Determinación de los requerimientos y técnicas de actualización de las herramientas de protección frente a código malicioso
5. Relación de los Registros de Auditoría de las herramientas de protección frente a código maliciosos necesarios para monitorizar y supervisar su correcto funcionamiento y los eventos de seguridad
6. Establecimiento de la monitorización y pruebas de las herramientas de protección frente a código malicioso
7. Análisis de los programas maliciosos mediante desensambladores y entornos de ejecución controlada.

1. Sistemas de detección y contención del código malicioso

1.1. Principios y objetivos de la detección de código malicioso

- La detección de código malicioso es esencial para proteger los Sistemas de Información, ya que busca identificar y neutralizar amenazas antes de que causen daño, combinando prevención, alerta temprana y respuesta eficaz.

El Código malicioso como amenaza persistente

Código malicioso o malware, abarca todo tipo de programas, rutinas o fragmentos de código diseñados con el objetivo de interferir, dañar, exfiltrar, espiar o controlar de forma no autorizada los Sistemas de Información.

El propósito de la detección de código malicioso es identificar su presencia antes de que cause daño, y activar mecanismos de respuesta que impidan su ejecución o propagación. Por ello, la detección debe ser lo más temprana, precisa y contextual posible, y apoyarse en herramientas tecnológicas, protocolos técnicos y análisis especializados.

Objetivos fundamentales de los Sistemas de Detección

Todo Sistema de detección de malware debe perseguir tres objetivos fundamentales, que guían su diseño, implementación y mantenimiento:

- Prevención de la ejecución del código maliciosos: El Sistema debe bloquear o neutralizar el código antes de que se active. Esto puede lograrse mediante aislamiento, eliminación, neutralización en tiempo real o denegación de permisos de ejecución.
- Detección temprana y precisa: La identificación debe producirse lo antes posible dentro del ciclo de vida del ataque. Cuanto antes se detecta el código malicioso, menores son los daños, el coste de recuperación y el tiempo de inactividad.
- Facilitación de la respuesta y recuperación: Además de detectar y bloquear, el sistema debe generar alertas, registrar eventos y proporcionar información técnica que permita al equipo de seguridad analizar el incidente, aplicar medidas correctivas y evitar futuras reinfecciones.

Tipos de Técnicas de Detección

Para cumplir sus objetivos, los Sistemas de detección de código malicioso pueden utilizar diferentes técnicas, que se aplican de forma individual o combinada:

- Detección por firmas: Consiste en comparar el contenido del archivo o flujo con una base de datos de identificadores correspondientes a programas maliciosos conocidos. Es rápida y eficaz, pero no detecta variantes nuevas ni código ofuscado.
- Análisis heurístico: Evalúa el comportamiento potencial de un programa según reglas definidas. Detecta acciones sospechosas (modificar un registro, conectarse a puertos no autorizados, crear procesos ocultos). Es útil frente a variantes desconocidas, aunque puede generar falsos positivos.
- Análisis basado en comportamiento: Supervisa el comportamiento real de un programa en ejecución. Detecta acciones maliciosas mediante correlación de eventos, incluso aunque no se identifique ninguna firma previa.
- Técnicas de IA y ML: Algunos sistemas entrenan modelos que clasifican archivos o procesos como maliciosos o benignos a partir de grandes volúmenes de datos históricos. Estos modelos aprenden patrones complejos que pueden pasar desapercibidos con otras técnicas

1.2. Estrategias de contención y neutralización del código malicioso

- La contención y neutralización del código malicioso son pasos decisivos para limitar el daño y restaurar la seguridad tras una detección, combinando respuestas inmediatas y acciones correctivas adaptadas al riesgo.

- Aislamiento del dispositivo o segmento afectado
- Cuarentena del dispositivo o proceso sospechoso
- Interrupción de procesos maliciosos
- Bloque de comunicaciones externas asociadas
- Reglas de contención en tiempo real aplicadas
- Neutralización/erradicación (desinfección, eliminación, reparación, reinstalación)

Principios de contención eficaz

Una vez detectado un código malicioso, el siguiente paso consiste en impedir su propagación, su ejecución completa o su interacción con otros sistemas o usuarios (**Contención**). Es una fase crítica para limitar los daños y evitar la escalada del incidente.

La Contención debe llevarse a cabo de manera rápida, controlada y proporcional al riesgo detectado, evitando tanto la diseminación del malware como la interrupción innecesaria de servicios legítimos. Un buen Sistema de Protección aplica medidas de contención de forma automatizada, escalable y documentada.

Técnicas habituales de Contención

Las estrategias de contención pueden clasificarse en función del momento en que actúan y del tipo de intervención que realizan:

- Aislamiento del dispositivo afectado: El Sistema de protección desconecta el equipo sospechoso de la red para evitar que se comunique con otros dispositivos, servidores o recursos compartidos.
- Cuarentena del archivo o proceso: Se impide la ejecución del código malicioso moviéndolo a un entorno controlado inaccesible para el SO y los usuarios. La cuarentena permite conservar el archivo para su análisis posterior, sin que pueda causar daños.
- Interrupción de procesos maliciosos en ejecución: Algunos sistemas permiten detener de forma inmediata los procesos que presenten comportamientos sospechosos, evitando que completen su tarea.
- Bloqueo de comunicaciones asociadas al código malicioso: Se bloquea el acceso a direcciones IP, dominios o puertos utilizados por el malware para descargar componentes adicionales o comunicarse con su centro de mando. Esta técnica es útil frente a troyanos y ransomware.
- Aplicación de reglas de contención en tiempo real: En entornos avanzados pueden definirse reglas que impidan ciertas acciones: modificación de archivos del sistema, ejecución de binarios desconocidos, escritura en unidades extraíbles, …

Neutralización y erradicación del código maliciosos

Tras la contención, es necesario eliminar completamente el código malicioso del sistema afectado, proceso que se denomina **Neutralización** o **Erradicación.**

Esta etapa requiere una intervención más completa y puede incluir:

- Desinfección automática del archivo o sistema: Algunos antivirus o antimalware son capaces de eliminar el código malicioso de un archivo infectado sin afectar al archivo legítimo, además de limpiar claves de registro, servicios, tareas programadas u otros elementos residuales.
- Eliminación total del archivo o componente malicioso: Si no es posible desinfectar, se opta por eliminar completamente el archivo o proceso asociado. En ocasiones, también se eliminar archivos temporales, réplicas u copias ocultas.
- Reparación de daños causados: Cuando el código malicioso ha realizado modificaciones en el sistema, es necesario restaurar configuraciones, recuperar archivos de copias de seguridad y auditar el estado general del equipo.
- Reinstalación o reimposición de imagen segura: En casos graves infecciones persistentes, la medida más segura puede ser la restauración completa del SO, partiendo de una imagen de confianza previamente generada y certificada

2. Relación de los distintos tipos de herramientas de control de código malicioso en función de la topología de la instalación y las vías de infección a controlar

2.1. Clasificación de herramientas de control de código malicioso según la topología de la instalación

- La protección frente al código malicioso depende tanto de la variedad de herramientas disponibles como de su correcta ubicación en la infraestructura tecnológica

El entorno como factor determinante en la protección

La elección y despliegue de las herramientas de control de código malicioso no puede ser uniforme, sino que debe adaptarse a la topología específica de cada entorno tecnológico. Esto significa que la arquitectura física y lógica de la red, los roles de los dispositivos y la distribución de los servicios condicionan el tipo, el alcance y la configuración de las herramientas a utilizar.

Factores claves que condicionan esta elección:

- Número y tipo de nodos: estaciones, servidores, dispositivos móviles, IoT, …
- Distribución geográfica o lógica de la red (centralizada, distribuida, segmentada, en la nube…)
- Nivel de acceso de los distintos dispositivos (usuarios estándar, administradores, equipos críticos)
- Presencia en entornos híbridos: físico+virtual+cloud
- Exposición a Internet o uso de redes privadas

Tipos de Herramientas según la ubicación en la infraestructura

Las herramientas de control de malware se clasifican habitualmente según su ubicación en la topología de la instalación. Esta ubicación condiciona tanto su alcance como el tipo de amenazas que pueden controlar.

Tipos de herramientas:

- Herramientas en el puesto de trabajo (endpoint)
- Herramientas en servidores o sistemas críticos
- Herramientas perimetrales o en red
- Herramientas basadas en la nube (cloud-based)
- Sistemas integrados de seguridad multiplataforma

Tipo de herramienta	Ubicación topológica	Características principales	Limitaciones principales
Protección en el puesto de trabajo	Terminales, portátiles, dispositivos móviles	Visibilidad del comportamiento local, bloqueo inmediato	Vulnerables a desactivación local
Protección en servidores	Equipos que prestan servicios críticos	Cuarentena reforzada, reglas estrictas	Puede afectar al rendimiento del servicio
Protección perimetral o de red	Pasarelas, firewalls, proxies	Filtro preventivo del tráfico, control de entrada/salida	Limitación frente a tráfico cifrado o amenazas internas
Herramientas en la nube	Gestión remota de dispositivos distribuidos	Actualización constante, visibilidad global	Requiere conectividad segura
Sistemas integrados (plataformas XDR)	Multinivel: endpoint, red, nube	Visión centralizada, correlación de eventos, respuesta automatizada	Complejidad técnica y organizativa

2.2. Herramientas según las vías de infección que se pretende controlar

- La defensa contra el código malicioso exige herramientas que actúen como "filtros inteligentes", interceptando las rutas que elige el atacante para infiltrarse.

Estrategias de Defensa Cibernética:

- Sinergia de Herramientas: Interacción entre herramientas para una defensa mejorada
- Herramientas de Mitigación: Mecanismos para contrarrestar amenazas cibernéticas
- Vías de infección: Puntos de entrada para amenazas cibernéticas

La Vía de infección como criterio de diseño de defensa

Además de tener en cuenta la topología de la instalación, la elección de herramientas de control de malware debe considerar por qué vía puede entrar el código malicioso en el sistema. Este enfoque permite implementar controles adaptados a los vectores más habituales, reforzando así los puntos más vulnerables del entorno.

Las vías de infección se refieren a los mecanismos técnicos y conductuales mediante los cuales el malware accede a un Sistema o se ejecuta en él, como puede ser el correo electrónico, la navegación web, los dispositivos USB o la explotación de vulnerabilidades.

Vía de infección	Mecanismo de entrada típico	Herramientas de protección recomendadas
Correo electrónico	Archivos adjuntos, enlaces maliciosos	Pasarelas antiphishing, escaneo de adjuntos, bloqueo de macros
Navegación web	Descargas, scripts embebidos, sitios comprometidos	Filtros de url, proxys, Secure Web Gateways, políticas del navegador
Dispositivos externos	Ejecución automática desde USB o SD	Control de puertos, escaneo automático, desactivación de autorun
Red local o compartida	Gusanos, ataques de red internos	Segmentación, IDS/IPS, EDR, control de puertos
Explotación de vulnerabilidades	Fallos en sistemas o software	Gestión de parches, escáneres, IPS, protección contra exploits
Software manipulado (troyanos)	Aplicaciones aparentemente legítimas	Control de aplicaciones, verificación de integridad, sandboxing

3. Criterios de seguridad para la configuración de las herramientas de protección frente a código malicioso

3.1. Parámetros de configuración críticos en las herramientas antimalware

- La configuración adecuada de las herramientas antimalware es un factor determinante para garantizar una protección efectiva y minimizar los riesgos de infección en cualquier entorno tecnológico.

Importancia de una configuración segura

Una herramienta antimalware puede perder su eficacia si no está correctamente configurada. Por defecto, muchas de estas soluciones vienen con ajustes básicos de orientados a minimizar conflictos con el usuario o el rendimiento, pero no a garantizar un nivel de protección óptimo. Por tanto, una configuración técnica apropiada es esencial para que la herramienta actúe de forma proactiva, eficaz y con mínima exposición al riesgo.

La configuración debe responder a criterios objetivos de seguridad y alinearse con:

- El perfil de riesgo de la organización
- Las características de los dispositivos donde se instala
- El tipo de amenazas predominantes
- Las políticas internas de TI y Ciberseguridad

Parámetros esenciales a configurar

Los siguientes parámetros son considerados críticos para asegurar un nivel adecuado de protección. Su activación o ajuste debe ser prioritaria en cualquier herramienta antimalware, ya sea instalada en puestos de trabajo, servidores o dispositivos móviles.

- **Protección en tiempo real**: Debe estar activada en todo momento para analizar archivos, procesos y tráfico conforme se ejecutan
- **Escaneo automático de medios extraíbles y unidades de red**: Permite detener amenazas antes de que se activen por parte del usuario.
- **Frecuencia y profundidad del análisis programado**: Deben definirse análisis periódicos completos del Sistema (diarios, semanales), sin depender solo de la protección en tiempo real
- **Acciones automáticas ante detección**: Es recomendable utilizar herramientas que actúen ante una detección, sin esperar confirmación del usuario: cuarentena, eliminación, bloqueo…
- **Actualización de firmas y motor**: La actualización debe ser automática y frecuente, y no debe de incluir solo la Base de datos de firmas, sino también el motor de análisis y heurística
- **Control del comportamiento y bloqueo de acciones sospechosas**: Muchos antivirus incluyen módulos que detectan comportamientos anómalos, estos módulos deben estar activados incluso si no hay coincidencia con una firma conocida
- **Protección frente a modificaciones y desactivación**: Es fundamental que la herramienta esté protegida contra su desinstalación, desactivación o modificación por parte de usuarios no autorizados.

Parámetro crítico	Descripción técnica	Motivo de activación prioritaria
Protección en tiempo real	Escaneo constante de archivos, procesos y tráfico	Detecta y bloquea amenazas en el momento de su ejecución
Escaneo de medios y red	Análisis automático de USB y carpetas compartidas	Impide infección por dispositivos externos o unidades compartidas
Frecuencia de análisis programado	Revisión completa periódica del sistema	Detecta amenazas persistentes o inactivas
Acción automática ante detección	Cuarentena, eliminación o bloqueo sin intervención del usuario	Evita demoras que permitan ejecutar el código malicioso
Actualización automática	Descarga de nuevas firmas y versiones del motor	Asegura la detección de amenazas recientes o modificadas
Control del comportamiento	Identificación de patrones maliciosos sin depender de firmas	Detecta ataques tipo zero-day o fileless (sin archivo)
Protección contra desactivación	Impide la manipulación o desinstalación no autorizada	Asegura la continuidad de la protección frente a atacantes

3.2. Políticas de restricción y excepciones seguras en entornos profesionales

- La Seguridad de los entornos profesionales exige políticas que bloqueen proactivamente amenazas potenciales, priorizando la prevención sobre la detección reactiva.

Estrategias de Seguridad Proactiva:

- Denegación por defecto
- Filtros técnicos
- Excepciones seguras
- Mejora continua

Fundamentos de las Políticas de Restricción

En entornos corporativos, no es suficiente con confiar en la detección automática del código malicioso, es necesario aplicar políticas de restricción proactivas, que limiten por defecto aquello que pueda suponer un riesgo, permitiendo solo lo que haya sido previamente verificado o aprobado. Este principio de seguridad se denomina **modelo de denegación por defecto**.

Estas políticas ayudan a:

- Reducir la superficie de ataque
- Limitar la capacidad del malware para ejecutarse, propagarse o alterar el sistema
- Impedir la ejecución del código no autorizado incluso antes de que sea reconocido como malicioso
- Cumplir con normativas de seguridad (ENS, ISO 27000, RGPDM NIS2,…)

Tipos de Políticas de Restricción aplicables

Existen distintas técnicas y mecanismos para aplicar políticas restrictivas en relación con la ejecución de código y el uso del Sistema:

- **Control de aplicaciones (application whitelisting)**: Solo se permite la ejecución de aplicaciones que estén en una lista blanca validada.
- **Restricción por tipo de archivo y extensión**: Permite bloquear la ejecución de ciertos tipos de archivo en determinadas ubicaciones o para determinados usuarios.
- **Control de macros y contenido activo en documentos**: Se impide la ejecución automática de macros en documentos ofimáticos, principalmente si proceden de Internet, correo electrónico o dispositivos externos.
- **Restricción de ejecución desde ubicaciones no autorizadas**: Muchos malware se ejecutan desde carpetas temporales, descargas o unidades externas.
- **Limitación del uso de privilegios elevados**: Se debe aplicar el principio de privilegio mínimo , evitando que un usuario estándar pueda ejecutar código con permisos de administrador sin autorización explícita.

Gestión segura de excepciones

Toda política restrictiva necesita cierto margen para permitir excepciones justificadas, pero deben realizarse de forma controlada, minimizando el riesgo que conllevan.

La Gestión de Excepcione implica:

- **Justificación técnica y autorización previa**: Cada excepción debe estar documentada y aprobada por el personal autorizado, indicando el motivo, el alcance y la duración de la misma
- **Limitación del alcance y la duración:** Una excepción debe aplicarse únicamente a un equipo, usuario o período concreto, y retirarse tan pronto como deje de ser necesaria.
- **Supervisión y auditoría:** Deben registrarse todas las excepciones aplicadas, y revisarse periódicamente para verificar su validez y evitar que se conviertan en vectores de ataque persistente.
- **Aplicación mediante herramientas centralizadas:** Las excepciones no deben configurarse localmente, sino gestionarse desde consolas centralizadas que permitan control, trazabilidad y revocación rápida.

4. Determinación de los requerimientos y técnicas de actualización de las herramientas de protección frente a código malicioso

4.1. Requerimientos técnicos y operativos de actualización de las herramientas de protección frente a código malicioso

- La actualización constante de las herramientas de protección es un requisito esencial para anticiparse a las amenazas y mantener la eficacia de la defensa en cualquier organización.

Lograr una Protección eficaz con malware:

1. Actualizaciones técnicas: Actualizar regularmente firmas, motores y módulos para detectar nuevas
2. Elementos actualizados: Asegurar que todos los componentes de protección estén actualizados para una defensa integral
3. Conectividad estable: Mantener una conexión segura y continua con los servidores de actualización
4. Permisos adecuados: Otorgar los permisos necesarios para actualizaciones y operaciones efectivas
5. Compatibilidad de versiones: Validar la compatibilidad para evitar problemas de actualización
6. Política Centralizada: Implementar una gestión centralizada para actualizaciones consistentes
7. Notificaciones de Errores: Establecer mecanismos para alertar sobre fallos de actualización

Importancia de una configuración segura

El Código malicioso evoluciona constantemente: nuevas variantes, métodos de evasión y campañas dirigidas aparecen a diario. Frente a esta realidad, mantener actualizadas las herramientas de protección no es una opción, sino una obligación técnica y operativa.

La Actualización regular y automática de firmas, motores de análisis y módulos funcionales es una de las bases de la seguridad preventiva en cualquier organización.

Elementos que deben mantenerse actualizados

Las herramientas de protección frente a malware se componen de diversos elementos que, de forma conjunta, permiten la detección y neutralización de amenazas.

Todos estos deben mantenerse actualizados de forma periódica y automatizada:

- **Base de firmas o definiciones**
- **Motor de análisis y detección**
- **Módulos de comportamiento o heurísticos**
- **Reglas y políticas preconfiguradas**
- **Integración con inteligencia de amenazas (threat intelligence)**

Requerimientos operativos para una actualización eficaz

La actualización de herramientas de protección no solo depende de aspectos técnicos, sino también de condiciones operativas que deben cumplirse para que el proceso sea fiable y sostenido en el tiempo:

- **Conectividad estable con el servidor de actualizaciones:** El Sistema debe poder conectarse con el proveedor de seguridad o con un servidor de actualización interno. La comunicación debe ser segura, continua y sin restricciones de cortafuegos.
- **Permisos y credenciales adecuadas:** El agente antimalware debe tener permisos suficientes para ejecutar actualizaciones, acceder al sistema de archivos, detener procesos o modificar reglas si es necesario.
- **Compatibilidad entre versiones:** Las actualizaciones deben validarse previamente en entornos controlados para evitar incompatibilidades entre versiones del motor, del sistema operativo o de los componentes de red.
- **Política de actualización centralizada:** Es recomendable gestionar las actualizaciones desde una consola o servidor centralizado, especialmente en redes con múltiples equipos, para asegurar la homogeneidad y trazabilidad del proceso.
- **Notificación de errores o fallos de actualización:** El sistema debe contar con mecanismos que alerten cuando una actualización no se ha podido aplicar.

Elemento que actualiza	Función en la herramienta de protección	Riesgo si no se actualiza
Base de firmas	Detección de amenazas conocidas	Incapacidad para reconocer variantes recientes
Motor de análisis	Ejecución de la lógica de detección	Fallos técnicos, bajo rendimiento, cobertura limitada
Módulos heurísticos o de comportamiento	Detección de amenazas sin firma	Falsos negativos frente a técnicas zero-day
Reglas y políticas preconfiguradas	Activación automática de respuestas ante patrones	Ineficacia frente a amenazas emergentes o campañas activas
Integración con thereat Intelligence	Enriquecimiento con datos externos en tiempo real	Ceguera ante nuevas direcciones IP, URLs o campañas

4.2. Técnicas de actualización automática, centralizada y segura

- La Gestión Automatizada y centralizada de las actualizaciones es fundamental para garantizar una protección uniforme, eficiente y trazable frente al código malicioso en entornos profesionales.

Ventajas de una actualización automatizada y gestionada

La actualización manual de los sistemas antimalware es inviable en entornos profesionales con múltiples dispositivos, usuarios y sedes. Por ello, las soluciones actuales deben permitir actualizaciones automáticas, centralizadas y seguras, con mínima intervención humana y máxima trazabilidad.

Estas técnicas ofrecen ventajas operativas clave:

- Garantizan la uniformidad de la protección en todos los dispositivos
- Permiten detectar fallos de actualización en tiempo real
- Facilitan la auditoría y verificación periódica del estado de cada agente.
- Reducen el riesgo de errores humanos o retrasos en entornos distribuidos
- Cumplen con los requisitos ENS y otras normativas

Técnicas de Actualización automática y su funcionamiento

Existen varios mecanismos para llevar a cabo una actualización automática, cada uno con sus características particulares. Su elección dependerá de la escala del entorno, la arquitectura de red y el nivel de control requerido.

- **Actualización directa del proveedor (cloud-based)**: Cada dispositivo se conecta por sí mismo a los servidores del fabricante para descargar actualizaciones
- **Actualización desde servidor intermedio en la organización (modelo mirror)**: Un servidor local descarga los paquetes de actualización y los distribuye internamente a los agentes.
- **Actualización programada por políticas**: Se establece una planificación específica (frecuencia, horario, condiciones,…)
- **Activación mediante eventos o condiciones**: Algunas soluciones permiten activar la actualización si se detecta un evento específico (conexión a red interna, cambio de política, …)
- **Validación mediante hash, firma digital o control de integridad**: las actualizaciones deben incluir mecanismos que aseguren que los paquetes no han sido modificados.

Centralización de la gestión de actualizaciones

Más allá de automatizar el proceso, es indispensable contar con una consola centralizada que permita gestionar, supervisar y auditar las actualizaciones en todo el Sistema informático.

Las principales capacidades de una solución centralizada incluyen:

- **Panel de control unificado** con el estado de actualización de cada equipo
- **Políticas diferenciadas por grupo o rol**
- **Alertas ante fallos o retrasos** en la actualización de firmas o módulos
- **Informes periódicos exportables** para auditoría interna o cumplimiento
- **Compatibilidad con Sistemas de gestión de configuración**

Técnica de automatización automática	Características principales	Riesgos o limitaciones
Desde el proveedor (cloud)	Simplicidad, sin infraestructura interna	Falta de control, dependencia de conexión externa
Desde el servidor interno (mirror)	Control completo, optimización del ancho de banda	Requiere mantenimiento del servidor local
Programación por políticas horarias	Adaptación al contexto y uso real	Riesgo de ejecución incompleta si las condiciones no se cumplen
Activación por evento o condición	Gran flexibilidad	Complejidad en la implementación y validación
Validación por firma o hash	Garantiza la integridad del paquete	Imprescindible en entornos críticos y con datos sensibles
Gestión centralizada	Supervisión global, informes y control de excepciones	Necesita herramientas avanzadas y personal técnico cualificado

5. Relación de los Registros de auditoría de las herramientas de protección frente a código maliciosos necesarios para monitorizar y supervisar su correcto funcionamiento y los eventos de seguridad

5.1. Tipología y estructura de los registros de auditoría generados por las herramientas antimalware

Los Registros de Auditoría generados por las herramientas antimalware son fundamentales para la supervisión, el análisis forense y el cumplimiento normativo en la gestión de la Seguridad Informática.

Proceso de Gestión de Registros de Auditoría:

- **Recopilación de Datos**: Los registros se recopilan para su análisis
- **Análisis de Registros**: Los registros se analizan para detectar anomalías
- **Identificación de Amenazas**: Las amenazas de seguridad se identifican a partir de los registros
- **Respuesta a Incidentes**: Se toman acciones para mitigar las amenazas

Función y Valor de los Registros de Auditoría

Los Registros de Auditoría generados por las herramientas de protección frente a código malicioso constituyen una fuente de información esencial para la supervisión, trazabilidad y mejora continua de la Seguridad Informática.

Estos registros permiten:

- Verificar el correcto funcionamiento del software de protección
- Analizar y reconstruir Incidentes de Seguridad
- Detectar anomalías operativas o de configuración
- Cumplir requisitos legales y normativos como ENS, RGPD, o ISO 27001.

Tipos de registros generados por las herramientas antimalware

Las herramientas de protección frente a malware pueden generar diferentes tipos de registros según el tipo de evento que documentan.

Los más relevantes son:

- Registro de detección de amenazas
- Registros de acciones automáticas
- Registros de escaneos programados o bajo demanda
- Registros de actualización del sistema antimalware
- Registros de acceso y administración
- Registros de errores y funcionamiento interno.

Estructura técnica de los registros estándares

Para que los registros sean útiles, deben seguir una estructura técnica clara, normalizada y compatible con sistemas de análisis.

Una entrada de registro bien definida incluirá:

- **Identificadores del evento:** Fecha y hora, código único del evento, y nivel de severidad (informativo, advertencia, crítico,…)
- **Información técnica del incidente:** Nombre del archivo, proceso o recurso afectado, ruta del objeto, método de detección, así como acción tomada.
- **Datos contextuales:** Usuario implicado, dispositivo desde el que se originó el evento, SO
- **Metadatos de integridad:** Hash del archivo, firma digital del registro, estado de verificación o correlación con otros eventos.

Los Registros de Auditoría de las herramientas antimalware permiten controlar su funcionamiento, documentar incidentes, cumplir normativas y facilitar el análisis forense. Incluyen eventos de detección, acciones tomadas, actualizaciones, escaneos, errores y accesos administrativos. Deben seguir una estructura clara, con metadatos técnicos y contexto.

5.2. Herramientas y métodos para la supervisión, correlación y conservación de registros antimalware

La Supervisión, Correlación y Conservación de registros antimalware son procesos interdependientes que garantizan la trazabilidad, el análisis forense y el cumplimiento normativo en la Gestión de Seguridad.

Marco de Seguridad Antimalware:

- **Supervisión activa**: Monitoreo en tiempo real para detectar amenazas emergentes
- **Correlación de eventos**: Vinculación de alertas para comprender el contexto de las amenazas
- **Conservación segura**: Almacenamiento seguro de datos para auditorías y análisis.

Supervisión activa de registros

Una vez generados los registros por las herramientas antimalware, su supervisión activa permite detectar patrones, anticiparse a incidentes y verificar el cumplimiento de las políticas de protección.

Esta supervisión debe realizarse mediante herramientas que ofrezcan:

- Monitorización en tiempo real de eventos críticos
- Paneles de control centralizados para la visualización de actividad
- Alertas automáticas por umbral, severidad o repetición de eventos
- Históricos consultables para análisis forense.

*Las soluciones más eficaces integran los registros antimalware con otras fuentes para ofrecer una visión completa del entorno de seguridad.

Correlación de eventos con otros Sistemas de Seguridad

La eficacia del análisis de registros mejora cuando se pueden correlacionar eventos provenientes de distintas fuentes, ya que permite identificar patrones complejos, campañas orquestadas o movimientos laterales dentro de una red.

Entre los sistemas más comunes que se integran con registros antimalware destacan:

- Sistemas de detección de intrusiones (IDS/IPS)
- Sistemas de autenticación y control de acceso (AD,LDAP)
- SIEMs (Security Information and Event Management)
- Plataformas EDR o XDR

Conservación segura y conforme a normativa

Los registros antimalware deben almacenarse de forma segura, accesible y conforme a la legislación vigente. Esto implica definir políticas claras de retención, protección contra la alteración y mecanismos de exportación para auditorías internas o externas.

Aspectos claves en la conservación:

- Duración del almacenamiento: mínimo, de 6 a 12 meses, aunque en algunos sectores puede ser mayor
- Protección contra la modificación: deben almacenarse en formatos inmutables y su acceso debe estar restringido, registrado y auditado.
- Exportación para análisis o peritaje: las herramientas deben permitir la exportación estructurada y cifrada para garantizar su validez forense.
- Respaldo y redundancia: la pérdida de registros puede tener consecuencias legales y operativas, por lo que deben implementarse sistemas de respaldo periódico y replicación.

Función de los registros	Técnica o herramienta recomendada	Objetivo operativo y normativo
Supervisión en tiempo real	Consolas centralizadas, SIEM, paneles de visualización	Detectar incidentes mientras ocurren
Correlación con otros sistemas	SIEM, EDR/XDR, Active Directory	Identificar patrones complejos y amenazas coordinadas
Almacenamiento seguro	Sistemas WORM, firmas digitales, control de acceso	Proteger la integridad y disponibilidad de los registros
Conservación conforme al ENS y RGPD	Políticas de retención, cifrado y replicación	Cumplir requisitos legales y permitir auditoría técnica
Exportación para auditoría o peritaje forense	Formatos normalizados con firma o hash	Garantizar la validez legal y técnica de la información registrada

6. Establecimiento de la monitorización y pruebas de las herramientas de protección frente a código malicioso

6.1. Monitorización de la eficacia operativa de las herramientas de protección frente a código malicioso

La Monitorización continua es imprescindible para asegurar que las herramientas de protección frente a código malicioso cumplen su función y permiten una mejora constante de la seguridad.

Proceso de monitoreo de Eficacia Antimalware:

- **Definir objetivos:** Establecer objetivos claros para el monitoreo antimalware
- **Establecer KPIs:** Desarrollar indicadores clave para medir la eficacia
- **Implementar herramientas:** Utilizar herramientas centralizadas para la recopilación y análisis de datos
- **Analizar Datos:** Evaluar los datos recopilados para obtener información
- **Ajustar Políticas:** Refinar políticas y procesos basados en los resultados

Objetivos de la Monitorización continua

Una herramienta antimalware no debe considerarse eficaz por el simple hecho de estar instalada. Es necesario aplicar una monitorización continua y sistemática que permita verificar si la solución está funcionando correctamente, si protege adecuadamente el entorno y si responde eficazmente ante nuevas amenazas.

Los objetivos principales de esta monitorización son:

- Detectar fallos de funcionamiento (servicios detenidos, módulos desactivados, errores en actualizaciones, …)
- Identificar infecciones no detectadas o parcialmente contenidas
- Analizar la cobertura real del entorno (dispositivos protegidos, archivos analizados,…)
- Evaluar la eficacia de las reglas, firmas y heurísticas
- Facilitar la toma de decisiones y la mejora continua

Indicadores clave para la supervisión de eficacia

Para evaluar correctamente el funcionamiento de las herramientas antimalware, es fundamental definir una serie de indicadores clave de rendimiento (KPIs). Estos indicadores deben ser medibles, periódicos y orientados a la acción correctiva.

Los principales KPIs utilizados en entornos profesionales son:

- Tasa de cobertura de dispositivos protegidos
- Porcentaje de detección efectiva
- Tasa de falsos positivos y falsos negativos
- Frecuencia de actualizaciones exitosas
- Cumplimiento de escaneos programados
- Tiempos medios de detección y respuesta

Herramientas para la monitorización centralizada

En entornos profesionales, la monitorización se realiza mediante herramientas específicas que permiten recoger, centralizar y analizar todos los indicadores clave de manera visual y automática.

Entre las más utilizadas se encuentran:

- Consola de gestión de endpoints (EDR, XDR, MDM)
- Sistemas SIEM
- Dashboards y paneles de control personalizados
- Herramientas de ticketing y seguimiento

Indicador clave (KPI)	Qué mide	Herramienta habitual de supervisión
Cobertura de dispositivos protegidos	% de dispositivos con protección activa y actualizada	Consola ERD/XDR, MDM
Detección efectiva	Amenazas detectadas frente a simuladas o conocidas	Consola de gestión, threat hunting
Falsos positivos/negativos	Precisión de las alertas generadas	Informes de incidentes, análisis retrospectivo
Actualización de firmas y motores	% de dispositivos con última versión aplicada	Panel de control de actualizaciones
Cumplimiento de escaneos programados	Ejecución de análisis según calendario establecido	Consola EPP/EDR, tareas programadas
Tiempos de detección y respuesta	Rapidez de la herramienta ante nuevas amenazas	SIEM, EDR, informes cronológicos de eventos

6.2. Pruebas de validación periódica de la funcionalidad y cobertura antimalware

Necesidades de verificar periódicamente el Sistema de Protección

Aunque una herramienta antimalware esté correctamente instalada, configurada y actualizada, es imprescindible realizar pruebas periódicas de validación que permitan confirmar que:

- Los componentes funcionales de la solución están activos y operativos
- Las firmas y los módulos de detección funcionan correctamente a lo esperado
- El sistema detecta, bloquea y registra las amenazas simuladas
- La cobertura efectiva alcanza todos los dispositivos y vectores relevantes.

Estas pruebas forman parte del ciclo de mejora continúa de la Seguridad, y deben estar recogidas en el Plan de Mantenimiento preventivo de ciberseguridad, como parte de la estrategia de defensa activa.

Tipos de Pruebas de Validación

Las Pruebas pueden clasificarse según su objetivo y el tipo de técnica que emplean. Es recomendable combinar distintas pruebas para cubrir tanto el plan funcional como el de comportamiento real.

- Pruebas de detección básica (archivo de prueba estándar)
- Pruebas de comportamiento simulado (Simulation Freamworks)
- Pruebas de malware real en entorno aislado (Sandbox)
- Pruebas de evasión y resistencia a técnicas antifirma
- Pruebas de integración y correlación

Planificación y Ejecución de Pruebas

Para que las pruebas sean eficaces, deben estar debidamente planificadas, documentadas y validadas.

Las buenas prácticas son:

- Definición de objetivos claros
- Planificación periódica y sistemática
- Ejecución controlada y sistemática
- Documentación y análisis de resultados

Las pruebas de validación permiten verificar que las herramientas antimalware siguen siendo eficaces en el tiempo.

Tipo de prueba	Finalidad principal	Consideraciones clave
Archivo de prueba estándar (EICAR)	Verificar respuesta del motor y generación de alertas	Inofensivo, válido para producción
Simulación de comportamiento sospechoso	Evaluar heurística y análisis dinámico	Requiere scripts controlados o herramientas especializadas
Pruebas en entorno aislado con malware	Validar detección frente a amenazas reales	Sólo en entornos de laboratorio y por personal técnico experto.
Pruebas de evasión antifirma	Comprobar resistencia ante técnicas de ocultación	Imprescindibles para validar robustez del motor
Verificación de integración con SIEM	Confirmar trazabilidad y respuesta en el ecosistema de seguridad.	Garantiza coherencia y visibilidad operativa

7. Análisis de los programas maliciosos mediante desensambladores y entornos de ejecución controlada

7.1. Fundamentos del análisis estático mediante desensambladores

El Análisis estático descompone el código malicioso en sus elementos esenciales, revelando su lógica interna sin exponer el entorno a riesgos de ejecución.

Paso para lograr un análisis estático integral:

1. **Desensamblado técnico:** Traducir binarios a código ensamblador para exponer detalles críticos
2. **Etapas de Investigación:** Identificar formatos, extraer metadatos y reconstruir el flujo lógico
3. **Inteligencia Aplicada:** Generar IOC y perfiles de amenazas para una detección proactiva

Concepto de Análisis Estático

El Análisis estático es una técnica forense que permite examinar un archivo malicioso sin necesidad de ejecutarlo. A través de herramientas especializadas como los desensambladores, se ejecuta el código binario o ensamblador de n ejecutable, lo que permite comprender su estructura interna, funcionalidades ocultas y posibles comportamientos, incluso si está diseñado para evadir la detección durante la ejecución.

Concepto de desensamblador

Un desensamblador es una herramienta que convierte un archivo binario ejecutable en código ensamblador legible, siguiendo las convenciones del procesador para el que fue compilado.

Los desensambladores más comunes son:

- IDA Pro: ampliamente utilizado en investigación de seguridad
- Ghidra: solución de código abierto desarrollada por la NSA
- Radere2: herramienta modular y flexible, también libre
- Hopper, Binary Ninja: entornos de análisis comercial con funciones gráficas avanzadas

Etapas del Análisis Estático

El análisis mediante desensamblador se puede dividir en varias fases, cada una con objetivos y herramientas específicas:

- **Identificación del tipo de archivo y estructura**: se determina el formato, el SO de destino y si el archivo está ofuscado o comprimido con un packer.
- **Extracción de metadatos e indicadores**: se buscan cadenas de texto, nombre de funciones, referencias a dominios, claves, nombres de usuarios o rutas sospechosas, así como firmas malware conocidas
- **Análisis del flujo de ejecución**: se sigue la lógica del código para entender qué operaciones realiza
- **Detección de técnicas de evasión o persistencia**: se buscan instrucciones que indiquen antianálisis, inyección de procesos, creación de servicios, tareas programadas, …
- **Elaboración de un informe de inteligencia**: se documentan los comportamientos identificados, se crean firmas personalizadas y se generan indicadores de compromiso para futuras detecciones.

Fase del análisis estático	Objetivo principal	Herramientas asociadas
Identificación del tipo de archivo	Conocer el formato, sistema y ofuscación	PEiD, Binwalk, Detect It Easy
Extracción de cadenas y metadatos	Obtener información textual o estructural útil	Strings, Ghidra, IDA Pro
Análisis del flujo de ejecución	Seguir la lógica del código y detectar comportamientos ocultos	IDA Pro, Ghidra, Radare2, Binary Ninja
Detección de técnicas de evasión	Identificar antianálisis, persistencia, escalada de privilegios	Análisis manual con desensamblador
Documentación de hallazgos	Generar informes, firmas, IOC e inteligencia de amenazas	YARA, informes PDF, bases de datos IOC

7.2. Análisis dinámico en entornos de ejecución controlada (sandboxing)

El Análisis dinámico desenmascara el comportamiento real del código malicioso al ejecutarlo en un entorno seguro, revelando acciones ocultas que escapan a las técnicas estáticas.

¿Qué tipos de sandbox se pueden utilizar para el análisis dinámico?

- Sandbox local: ideal para análisis manual y control total sobre el entorno
- Sandbox en la nube: Ofrecida por proveedores de seguridad, proporcionando escalabilidad y experiencia externa.
- Sandbox automatizada: Adecuada para analizar múltiples muestras simultáneamente, ahorrando tiempo.

Concepto de Análisis Dinámico

El Análisis dinámico consiste en ejecutar una muestra de código malicioso en un entorno controlado, para observar su comportamiento real: qué archivos crea, qué conexiones establece, qué procesos inicia, qué servicios modifica,… A diferencia del análisis extático, aquí no se estudia el código directamente, sino sus efectos sobre el sistema.

Cómo funciona una sandbox

Una Sandbox es un entorno virtual o físico aislado del sistema real, diseñado para permitir la ejecución controlada de programas potencialmente maliciosos. Dispone de herramientas de monitorización para registrar la actividad de la muestra sin que esta pueda afectar a otros equipos o sistemas.

Elementos clave de una sandbox:

- Sistema operativo limpio, replicable, restaurado tras cada prueba
- Monitorización de procesos, archivos, red, memoria, registros, …
- Bloqueo de comunicación hacia Internet real o redirección a entornos simulados
- Herramientas de captura de hashes, llamadas a API, secuencias de eventos
- Entorno diseñado para parecer legítimo y evitar ser detectado como virtual.

Tipos de sandbox:

- **Locales o manuales**: ejecutadas por analistas de seguridad en equipos aislados
- **Automatizadas y centralizadas**: plataformas que permiten analizar múltiples muestras simultáneamente
- **En la nube (cloud sandboxing)**: análisis externo ofrecido por proveedores de seguridad.

Indicadores extraídos del análisis dinámico

El Análisis en sandbox proporciona una gran cantidad de información útil, especialmente para generar inteligencia de amenazas e indicadores de compromiso (IOC).

Entre los más relevantes se encuentran:

- Archivos creados o modificados
- Procesos iniciados o inyectados
- Conexiones de red salientes
- Acciones sobre el sistema
- Persistencia y evasión

Buenas prácticas y limitaciones

El Análisis dinámico es una herramienta poderosa, pero también tiene limitaciones y riesgos si no se utiliza adecuadamente.

La Buenas prácticas son:

- Aislamiento total del entorno de análisis, sin conexión directa a la red real
- Restauración automática del sistema tras cada prueba, para evitar contaminación
- Simulación realista del entorno: usuarios activos, procesos comunes, interacción mínima.
- Combinación con análisis estático para una visión completa
- Documentación precisa de cada resultado, enlazado con el sistema de gestión de incidentes.

Elemento del análisis dinámico	Qué permite observar	Herramientas asociadas
Archivos modificados o creados	Detección de rutas, nombres y estructuras comunes	Cuckoo, FireEye, Joe Sandbox
Procesos iniciados o inyectados	Descubrimiento de procesos ocultos o manipulados	Monitor de procesos, ProcMon, Sysinternals
Conexiones de red salientes	Identificación de C2, exfiltración o descarga de cargas	Captura de paquetes, Wireshark
Acciones sobre el SO	Modificación del registro, tareas, servicios	RegShoit, herramientas propias de sandbox
Persistencia y evasión	Técnicas de sigilo, inicio automático, análisis del entorno	Registro de sandbox, revisión manual.